

Security Testing Summary – SauceDemo

DevelopersHubCorporation Internship | Domain: Software Quality Assurance (SQA)

Intern: Esha Tabbassum | ID: DHC-1019 | Date: March 19, 2026, |Tool: OWASP ZAP 2.17.0
|Target: <https://www.saucedemo.com/>

1. Objective

To identify security vulnerabilities in SauceDemo using OWASP ZAP, focusing on OWASP Top 10 risks including XSS, injection attacks, and security misconfigurations.

2. Scope

Application: Sauce Demo (<https://www.saucedemo.com/>)

Testing Type: Automated vulnerability scanning (Passive + Active)

Areas Tested: Homepage, HTTP headers, external resources, JavaScript files

3. Methodology

Passive Scanning: Crawled application to discover all pages and resources

Active Scanning: Performed automated attack simulations

Alert Analysis: Categorized 12 findings by risk level

4. Summary of Findings

Risk Level	Count	Key Findings
High	0	None detected
Medium	4	CSP missing, CORS misconfiguration, Missing X-Frame-Options, Missing HSTS
Low	4	Server version disclosure, Missing X-Content-Type-Options, Missing SRI, Suspicious comments
Informational	4	Timestamp disclosure, Modern web app, Cache issues
Total	12	

5. Key Observations

Medium Risk Issues (Fix Priority)

- **CSP Header Missing:** No protection against XSS attacks
- **CORS Misconfiguration:** `Access-Control-Allow-Origin: \*` allows any site to access resources
- **Missing X-Frame-Options:** Vulnerable to clickjacking
- **Missing HSTS:** No enforcement of HTTPS connections

Low Risk Issues

- **Server Version Disclosure:** Reveals hosting platform (GitHub)
- **Missing X-Content-Type-Options:** Potential MIME-sniffing risk
- **Missing SRI:** External CDN resources could be tampered with
- **Suspicious Comments:** Developer notes visible in source

Informational

- Timestamps in responses, modern app architecture, cache behaviors

6. Conclusion

The SauceDemo application has an **acceptable security posture** for a demo/training application. No critical vulnerabilities were found. However, implementing the recommended security headers would significantly improve security and align with industry's best practices.

7. Recommendations

1. Immediate Actions (Medium Risk):

- Implement CSP, HSTS, X-Frame-Options headers
- Fix CORS policy (remove wildcard `\*`)

2. Short-term Actions (Low Risk):

- Add X-Content-Type-Options header

- Implement SRI for external resources
- Remove server version headers
- Clean up code comments

3. Long-term Improvements:

- Regular security scanning
- Security training for developers
- Integrate security testing into CI/CD

Report Generated By: Esha Tabbassum

Date: March 19, 2026